# Your Data, Your Rules: Query-Layer Access for a Social Data Platform

Jacob Hoffman
web10 Inc.
jacob@web10.app

## ABSTRACT

Social applications typically implement content, audience relationships, and access rules in application-specific backends. **web10** places content and access relationships in a shared data platform, allowing applications to define their own queries while users manage group membership and grants. The platform stores documents under logical user namespaces in ClickHouse and exposes generic groups, service-scoped roles, app contracts, and a query API. Its central mechanism is a query boundary: application queries name services, and the node supplies filtered relations for the reader before executing joins and aggregations. The social application, web10-social, uses this mechanism to compose ranked posts, engagement, and profiles in a static browser frontend. A connected interoperability demonstration extends the composition to a game and a marketplace: both join their own records to social-written profiles without changing the social application or adding application-specific node endpoints. Desktop and mobile browser flows exercise actual consent and reuse; separate cross-author checks exercise app grants and private-group access. We describe the access model, query compilation, and the consistency obligations of a shared columnar store. A preliminary single-node microbenchmark shows the cost of metadata fan-out: at 1,000 candidate groups, batching reduced median readable-group resolution from 7,536 to 214 ms and median query-handler time from 7,645 to 363 ms in one sequential trial. Repeated trials, full application latency, capacity, revocation timing, and cost evaluation remain pending.

## 1 INTRODUCTION

For a creator, an audience is more than a list of accounts. It is a set of relationships: who follows, who belongs to a group, and who may read or contribute content. When those relationships live inside one application's backend, a new frontend must recover both the data and the rules that give it meaning. The database question is how to make content and access relationships reusable across applications while preserving the reader's authorization boundary.

**web10** addresses this question with a shared data plane and a small set of composable access primitives. A user's key identifies a logical namespace, not a separate database. Generic groups associate documents with audiences; roles name per-service operations; app contracts constrain supported calling contexts. An application supplies its own services and queries rather than requiring a new feed endpoint for each ranking or audience model.

The motivating application is a deployed creator-oriented social platform, including feeds, groups, direct messages, discovery, and monetization. Its feed illustrates the separation: an application chooses chronological or weighted ranking, while the node resolves the reader's access. A chronological query makes eligible posts retrievable without an engagement-based cutoff, subject to access and moderation rules. Here distribution means eligibility for retrieval; pagination and user attention determine what is actually viewed.

Reusing those relationships also means building applications outside the original social interface. A game can show a player's existing social identity alongside an earned score; a marketplace can show the same identity beside a listing. We implement both cases and verify that their queries reuse social-written profiles through the same access boundary. The applications share document conventions, not a bespoke social-to-game or social-to-marketplace API.

This work builds on the decentralized social web. ActivityPub defines activity delivery APIs [11]; ATProto separates repositories, relays, and application views [10]; Solid separates applications from personal data stores [15]. Solid's Web Access Control supports group agents [5], and its Access Control Policy includes a client dimension [3]. web10 brings user-facing contracts and application-written SQL together within one node's shared columnar store. This placement lets an application compose cross-service reads against relations filtered for its reader, rather than define a dedicated server endpoint for each social view.

We use *generic social composition* to mean that app-defined content and relationships are represented through service-namespaced documents, generic group membership, role maps, and queries. Generic group-management endpoints are part of this substrate. The node also provides advertising, content-event, media, and result-preparation machinery. The architectural separation is between application-defined content and query semantics and these shared node services.

This paper makes three contributions:

(1) **A compositional data/access architecture** (§2): logical user namespaces, app contracts, and group roles share a service-scoped permission vocabulary, exposed to application authors and users rather than only infrastructure operators.
(2) **A reader-specific query boundary** (§3): service references resolve to filtered CTEs before caller joins and aggregation. The implementation combines policy resolution, SQL validation, and boundary construction above a shared database account.
(3) **Application composition and connected reuse** (§4, §5.1): a deployed social frontend composes ranked feeds and scoped engagement reads; a game and marketplace reuse its profile data. Connected browser and cross-author checks exercise this reuse together with consent and independent app/group access controls.

The evaluation in §5 reports the connected interoperability checks and a preliminary metadata-resolution trial. These establish bounded composition behavior and expose an implementation bottleneck;

representative full-application latency, concurrent capacity, and comparative costs remain open measurements. §6 relates the design to decentralized storage, IAM, and multi-tenant databases; §7 concludes.

# 2 THE ACCESS MODEL

## 2.1 Two trust layers

For a group-scoped content operation, the model distinguishes an *app*, a *principal* (the acting user), a *group* $G$, a *service* $S$ (a data namespace such as `posts` or `comments`), and an *operation* $O$ (e.g. `readAll`, `create`). Authorization asks two questions where the corresponding gates apply:

| Layer | Question |
|---|---|
| App trust (outer wall) | Can this *app* perform $O$ on $S$? |
| Person trust (inner wall) | Does membership or a class/role grant allow $O$ on $S$ in $G$? |

The app contract expresses trust in a calling application. In the current document and query paths, authenticated browser-style tokens are checked against an origin-keyed contract when an HTTP `Origin` is present; without that header, this app-contract check is skipped. Anonymous queries also skip it. OAuth-delegated tokens instead select a `client_id`-keyed contract, including when no Origin is present. The node enables wildcard, non-credentialed CORS; endpoint code enforces application grants separately. Origin identifies the browser calling context, while the delegated token carries the OAuth client identity. Non-browser clients control their own Origin headers. Identity verification and document/group authorization are separate checks.

The group layer expresses trust in people. The split lets a user revoke an app grant without leaving a group, or leave a group without changing app grants.

## 2.2 Roles are per-service permission maps

A role is a named bundle of per-service permissions—a map from service to the operations it grants:

```
{ "name": "editor",
  "permissions": {
    "posts":    ["readAll", "create", "updateOwn"],
    "comments": ["readAll"]
  } }
```

The map *is* the scope. `'*'` wildcards all document services; a reserved key `'group'` carries *structural* operations on the group itself (`manageRoles`, `assignRoles`, `deleteGroup`, join/member operations), while *content* operations—including moderation such as `hideAll`—live under the service key, because they act on documents, not on the group's shape.

Two properties keep the model small. First, the role map is the *same shape* as the app-contract permission object: there is one permission language across both trust layers. Second, a person holds *one explicit member role* per group; compound permissions can be placed in that role rather than stacked through multiple assignments. Policies use positive grants; explicit deny and context-dependent conditions are outside this model. A group defines whatever roles fit its purpose (`owner`, `moderator`, `page-curator`, `member`, or `dj`, `listener`)— and applications supply their role definitions. Some lifecycle operations use conventional names such as `member`.

## 2.3 Principal classes and effective permissions

Access is granted to *principals*, of which there are three nested classes, broadest to narrowest:

| Class | Who |
|---|---|
| `anyone` | every request, signed in or not |
| `authenticated` | a verified non-anonymous user, member or not |
| `member` | holds a member row in this group |

The broad classes `anyone` and `authenticated` are represented by *reserved keys in the member table*; individual members use their own principal keys. No separate visibility table is needed. For example:

```
group_members:
  (G, 'anyone',        'reader')    -- the group is
       public
  (G, 'authenticated', 'reader')    -- signed-in users
       can read
  (G, 'bob',           'moderator') -- bob moderates
  (G, 'alice',         'owner')     -- alice owns
```

A principal's *effective* permissions in a group are the union of the permission maps of every class they belong to:

$$\begin{aligned}\text{effective}(P, G) \;=\; &\text{grant}(G,\ \texttt{anyone}) \\ \cup\ &\big(P \in \texttt{authenticated}\ ?\ \text{grant}(G,\ \texttt{authenticated}) : \emptyset\big) \\ \cup\ &\big(P \in \texttt{member}(G)\ ?\ \text{grant}(G,\ \text{role}(P)) : \emptyset\big)\end{aligned}$$

The content gate combines this grant union with membership admission. In `can_read_group` and `can_write_group` helpers, an active member is admitted for content reads and creates without requiring service-specific `readAll` or `create` in that member's role. For non-members, the class grants supply those permissions. Other role-controlled operations use their respective permission checks.

The union is monotone across principal classes under otherwise equal conditions. Blocks, sharing state, hidden documents, and node moderation apply additional visibility restrictions to the resulting content.

## 2.4 Publicness is a grant, not a flag

There is no `visibility` column. "Make my group public" is the act of granting `readAll` to `anyone`; "signed-in only" grants it to `authenticated`; "private" withholds those non-member grants. Join policy is orthogonal: it controls how a human *becomes* a member (open, request, invite-only) and says nothing about what a non-member bystander can see. A group can be invite-only to join and still publicly readable—the discovery board is exactly that.

This is the sense in which web10 brings IAM to the front: the operations a cloud operator would express as policies—*principal class, service, operation, grant*—are the operations an *end user* expresses about their own data. A grant is represented by metadata rows and revoked through tombstones. Subsequent checks use latest-row resolution. End-to-end revocation latency comprises database visibility, concurrent checks, in-flight requests, and the remaining lifetime of issued capabilities.

# 3 ENFORCEMENT AT THE QUERY LAYER

## 3.1 One columnar table

A ranked feed has analytical components: joins across authors and engagement, filtering, aggregation, and sorting. A social application also has point reads, updates, and coordination-heavy operations. web10 chooses ClickHouse [17] for both structured content and operational metadata rather than maintaining a separate Postgres-to-ClickHouse replication pipeline. User content occupies one shared `documents` table keyed by `(author_key, doc_id)`. The user namespace is logical isolation within that table, not a per-user database or physical collection. Large media objects reside in object storage. The following simplified schema omits reference and advertising fields:

```
CREATE TABLE documents (
    doc_id          String,
    author_key      String,
    collection_name String,   -- the service: 'posts', '
        comments', ...
    body            String,   -- JSON
    tags            Array(String),
    created_at      DateTime64(3),
    updated_at      DateTime64(3),
    deleted         UInt8 DEFAULT 0
) ENGINE = ReplacingMergeTree(updated_at)
ORDER BY (author_key, doc_id);
```

Updates insert a newer version; deletes insert tombstones. Background merges alone do not establish read correctness: reads must select the latest version *including tombstones*, then filter deleted rows. Filtering tombstones before deduplication can resurrect the previous version. Documents attach to groups through `doc_groups`; `group_contracts` and `group_members` hold contracts and assignments. These are narrower metadata tables whose size grows with groups and memberships.

One structured store removes a cross-database synchronization dependency. Its operational costs include version accumulation, merge pressure, read-time deduplication, point-query latency, and shared-resource contention. Multi-row content/membership changes and concurrent revocation require explicit consistency handling. Backup and recovery span database metadata and object storage; these are requirements of the design.

## 3.2 The query boundary: a wall, not a membrane

Application-written SQL over a multi-tenant store requires a boundary before the caller's relational operations. The query API accepts a constrained read-only SQL surface, not arbitrary database access. Its intended boundary is a *wall, not a membrane*: validated service references read reader-filtered CTEs, rather than raw tables whose output is filtered afterward. Correctness depends on validation coverage and SQL dialect interpretation, as discussed below.

*Why output-side filtering is unsound.* The natural design wraps the caller's query and filters the *result*, e.g. `SELECT * FROM (q) WHERE <filter>`. This fails because the caller's query has *already read the raw table* inside the parentheses, and an outer filter cannot undo an aggregation that baked everyone's data in:

```
-- counts every user's comments; the outer group filter
    is too late
SELECT author_key, count(*)
FROM documents WHERE collection_name = 'comments'
GROUP BY author_key
```

The aggregate has already collapsed all authors into counts before any row-level filter could run. Filtering the output of an aggregation is not access control.

*Redirecting the input instead.* web10 parses submitted SQL to an AST; it does not send that original string directly to ClickHouse. It validates table references and injects a *boundary CTE* under each referenced service name. The CTE deduplicates the service's documents, joins current `doc_groups` mappings, filters to readable groups, and applies block, sharing, hidden-document, and node-ban exclusions. Thus `SELECT ... FROM posts` resolves to a service CTE before aggregation or joins. The readable set can include public or authenticated-class grants, not just the reader's memberships. An empty set produces an empty service CTE. Before compilation, an authenticated request with explicit groups is rejected with 403 if none of its referenced services has a readable group. The query boundary does not automatically union in all reader-owned documents.

*The walk and the backstop.* The compilation is five steps: (1) parse to an AST (unparseable or multi-statement input is rejected); (2) check the statement kind (`SELECT` and supported set operations, not `INSERT`, `DROP`, etc.; this is not full SQL type checking); (3) walk every `Table` node, including inside caller CTEs and subqueries, rejecting raw node tables, ungranted services, and table functions (`file()`, `s3()`, `numbers()`, represented in the validated parser shapes as empty-named `Table` nodes); (4) inject the needed boundary CTEs ahead of the caller's CTEs and re-emit from the validated AST; and (5) *round-trip*—re-parse the compiled SQL and require it to come back as exactly one statement. The round-trip checks composition syntax. Targeted parser/engine tests exercise selected dialect and name-resolution cases. The executed query is emitted from the validated AST.

*Why place policy above ClickHouse?* web10 uses a shared database service account and constructs a reader-specific boundary combining membership, class grants, and visibility exclusions. This design puts policy orchestration in the application rather than provisioning a database account and policy for each end user. PostgreSQL policies offer another enforcement placement, using expressions, functions, and subqueries to consult dynamic authorization state [13]; an equivalent membership policy provides a comparison baseline for the cost of these enforcement placements.

*Trusted implementation.* The parser, validator, generated CTEs, identity resolution, metadata checks, and ClickHouse name-resolution semantics are in the trusted computing base. The service account must read raw tables to execute generated CTEs; its privileges do not independently enforce each reader's boundary. Repository tests cover selected top-level, caller-CTE, subquery, table-function, and aggregation cases, with a live-node E2E gauntlet for supported shapes. Parser and engine upgrades require renewed compatibility and adversarial testing.

### 3.3 Metadata resolution and relational cost

The read path is the heart of the design:

(1) **Resolve.** Take explicitly requested candidate groups, or discover the reader's memberships. Parse the query to identify its services.
(2) **Compute.** For each referenced service and candidate group, check active membership or resolve class grants through member and contract metadata. The current query endpoint calls `readable_groups`, which loops over candidates; a check may issue several metadata queries.
(3) **Execute.** Inject each service's readable-group set into its boundary CTE. ClickHouse performs document/mapping deduplication, the mapping join, visibility exclusions, and the caller's joins, aggregates, and sorting.

For $s$ referenced services and $g$ candidate groups, this path performs up to $sg$ group-gate evaluations, with early membership success reducing work within a check. The repository also has a batched helper used elsewhere; the query endpoint currently uses the per-group helper. Role resolution does not need content bodies, but its metadata I/O and the generated relational work both contribute to authorization cost.

The document-to-group join can yield multiple rows for one document attached to several readable groups. Applications must choose whether to retain those associations or deduplicate before counting and pagination. CTE expansion, join cardinalities, exclusions, and sorting can change database work and query plans. Evaluation accounts for both metadata resolution and this relational work.

### 3.4 Isolation rule and regression coverage

The intended isolation rule is that another author's document requires an authorized group path, including public or authenticated-class grants (invariant I3). The query path implements this through service CTEs. Permission-matrix and exploit-regression tests exercise the compiler and endpoint boundaries. CRUD, directory, group-attachment, preparation, and media paths have separate test scopes; §5.5 records the current coverage and open boundaries.

### 3.5 Document-linked media capabilities

Structured documents refer to binary objects in MinIO/S3-compatible storage. The intended linkage is document authorization followed by capability issuance: presigned URLs let browsers fetch individual objects directly; HLS uses short-lived signed manifests and segment capabilities, with document checks on manifest access. Expiry limits capability lifetime but does not retract bytes already fetched or guarantee immediate revocation.

The query prepare pass combines media resolution, HLS signing, advertising, and avatar preparation. This keeps capability issuance next to result preparation while object storage serves the media bytes. Its authorization boundary includes key ownership, authorized cross-user references, result projections, public thumbnails, and stale capabilities (§5.5).

### 3.6 Data policy, not privacy

web10 deliberately trusts the node operator with readable content. Search, ranking, moderation, and audit functions operate on plaintext. Tokens and signed capabilities protect application/user boundaries; terms govern operator conduct. This trust model supports node-side querying without requiring default end-to-end encryption.

Here *user-owned* denotes logical authorship namespaces and user-controlled grants. The operator retains physical access to hosted data, and legal remedies depend on terms, jurisdiction, and enforceability. Usable export and exit are broader product goals; interoperable migration and federation remain outside the demonstrated single-node architecture.

### 3.7 Implementation boundary

Python/FastAPI handles request validation, identity and permission orchestration, SQLGlot parsing/compilation, serialization, and result preparation. ClickHouse's native engine performs scans, joins, aggregation, filtering, and sorting. The node API source and TypeScript SDK are available alongside the query endpoint and boundary compiler. The production API command configures four Gunicorn processes with Uvicorn workers. This service/database division of work puts query execution in ClickHouse and orchestration in Python. Profiling separates API CPU, database CPU, I/O waits, and queueing to locate the costs of parsing, metadata round trips, response serialization, and preparation.

## 4 APPLICATION COMPOSITION

web10-social is the demonstration application built on web10: its persistent social data and authentication use web10 APIs and the SDK rather than a separate social-data backend. It exercises the architecture through feeds, social groups, direct messages, and discovery. These features require different content shapes and audience relationships over the same document and group substrate. The feed is a useful case study because it combines ranking, relationships, media, and multiple authorization scopes. We examine its query composition here; workload capacity is the subject of §5.

### 4.1 The killer-app hypothesis

web10-social is also the project's attempt at a *killer app*: an application compelling enough to attract users to a new platform. The longer-term vision is an open, decentralized ecosystem in which many applications reuse a shared data and access substrate. Social is the initial adoption vehicle and a demanding demonstration of that substrate. Adoption remains an open product goal; the case study examines the implemented application breadth.

The application spans a media spectrum from text and social relationships to images, short-form video, long-form video, and audio. Facebook, Instagram, Threads, TikTok, YouTube, and YouTube Music provide familiar reference points for these interaction patterns. Table 1 maps them to the demonstration's implemented surfaces. These reference points describe interaction patterns; the case study evaluates their composition on web10.

Different media and interaction patterns share document storage, audience relationships, engagement records, and access machinery, while their presentation and queries are defined by the

**Table 1: Media and interaction patterns covered by the demonstration. Platform names identify familiar interaction patterns.**

| Demonstration surface | Familiar reference |
|---|---|
| Communities, text posts and discussions | Facebook, Threads |
| Image and mixed-media posts | Instagram |
| Vertical short-video browsing | TikTok |
| Long-form video watch pages | YouTube |
| Audio-track browsing and playback | YouTube Music |

client. The architectural demonstration is that this range of social experiences can be built on web10's APIs. A successful adoption vehicle would bring those users and their relationships into the wider application ecosystem.

## 4.2 A frontend application over the shared node

The application is a React/TypeScript SPA. Its data client connects to the node; social operations express posts, conversations, relationships, and feeds through web10's document, group, query, and media interfaces. This is backendless from the application developer's perspective: web10 supplies the backend, while the application supplies its data conventions, queries, and interface. The browser build consists of static assets and can be hosted independently, for example in S3 behind HTTPS/CDN and SPA route handling.

The current deployment also includes a small Node link-preview renderer for crawlers. That presentation component uses web10 APIs and holds no separate social-data store; a static-only deployment needs a separate arrangement for crawler cards. Media bytes transfer through API-issued object-storage URLs, and real-time peer traffic uses the SDK's RTC support. Telemetry and external embeds are additional network paths. Application data and authentication use the node; media delivery and these ancillary connections follow their respective transport paths.

At source revision `317fa349e`, the application-local frontend contains **46,285 physical source lines across 141 files**: 45,846 TypeScript/TSX lines and 439 CSS lines under `src/`, excluding tests. Its local tests contain another 31,060 lines in 105 files; the link-preview renderer is 431 lines in three JavaScript modules. Counts include comments, blank lines, and local type declarations. They exclude public/generated assets, dependencies, configuration, tooling, and sibling shared-library and SDK implementations. Implementation links for this application case study use that pinned revision; the later experiment snapshots are identified separately in §5.1 and §5.2.

## 4.3 The feed as a query

The application's feed implementation builds a query over `posts`, `reactions`, `comments`, and `profile`. It chooses chronological or weighted ranking, joins engagement aggregates and author profiles, and supplies cursor conditions. The node resolves those service names through the boundary CTEs. Preparation can attach advertising and resolve media, HLS manifests, and author avatars

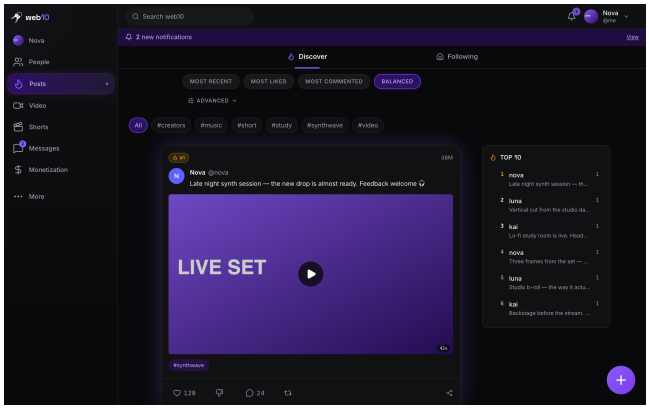



**Figure 1: The web10 feed. The reader chooses the ranking (Most Recent / Most Liked / Most Commented / Balanced) and filters (tags); each is a different application query over the same columnar store. The main query uses reader-specific service boundaries; engagement and view metrics also use follow-up calls.**

on returned rows. This separates the application's feed definition from a dedicated feed endpoint, while retaining explicit server-side preparation machinery.

Three implementation observations define the scope of the case study:

(1) **Page assembly.** For a nonempty page with post IDs, `readFeedPage` issues the main query, then two engagement queries (reactions and comments) and a `contentViews` call. Group discovery precedes this work, and media bytes require separate fetches. UI-level reaction-state reads and other screen activity may add calls. Page assembly therefore combines one main composition query with scoped follow-up reads.

(2) **Authorization scope affects semantics.** The main query's engagement joins use the feed-group scope, while engagement documents may live in the discovery group. The follow-up queries use the union of feed groups and discovery to populate displayed counts. Counts are relative to readable relations, not necessarily global totals. The displayed counts can therefore differ from the counts used by the main ranking query.

(3) **The query is application-defined.** Ranking and filtering can change without adding a dedicated node feed endpoint. Applications can select their ranking and projections while reusing the same boundary construction and preparation services.

Evaluation will measure both the complete page-assembly path and its main query, recording client-call counts, internal metadata queries, and database work separately alongside latency and throughput.

## 4.4 Multiple applications, one data plane

The social application is a producer of reusable data, not the only client of the node. Two small static applications consume its `profile` documents: Snake associates completed runs with player identities; Marketplace associates listings with seller identities. Each writes

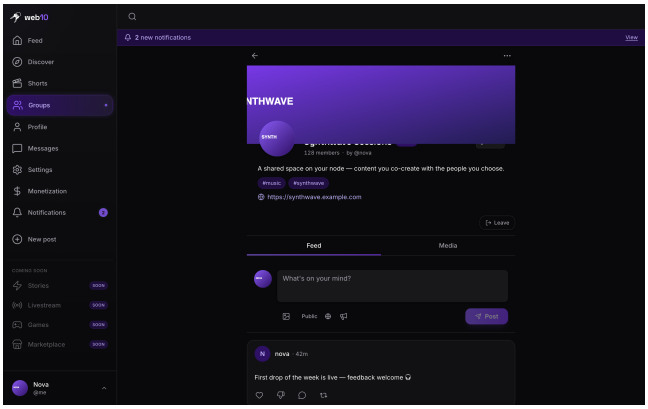



**Figure 2: A group—"a shared space on your node." Membership, roles, and per-post visibility (Public / node / group) expose application choices over the generic groups and grants of §2.**

**Table 2: Data producers and consumers in the connected demonstration. Other social services are omitted.**

| Application | Writes | Reuses |
|---|---|---|
| web10-social | `profile` | — |
| Snake | `snake_scores` | `profile` |
| Marketplace | `marketplace_listings` | `profile` |

its own service and reads the existing profile format (Table 2). Neither modifies web10-social or adds a game, commerce, leaderboard, or seller-profile endpoint to the node. The common dependency is the document convention and access primitives, not an application-specific API agreement.

The following abbreviated leaderboard query illustrates the seam. Both service names resolve to reader-filtered relations before the join. The full application also selects each player's best score and supplies profile-media preparation.

```
WITH latest_profiles AS (
  SELECT author_key, body FROM profile
  QUALIFY row_number() OVER (
    PARTITION BY author_key
    ORDER BY updated_at DESC, created_at DESC,
             doc_id DESC) = 1
)
SELECT s.author_key,
       JSONExtractInt(s.body, 'score') AS score,
       p.body AS profile_body
FROM snake_scores s LEFT JOIN latest_profiles p
  ON s.author_key = p.author_key
ORDER BY score DESC LIMIT 50
```

Application permission to read scores does not confer permission to read profiles; an app-level profile grant does not itself grant access to a private profile group. This outer join can retain a score without a readable profile. The independent group control in §5.1 checks the corresponding inner-join exclusion while the score records remain readable. Applications therefore compose authorized relations, not unrestricted copies of another application's data.

Figure 3 shows the resulting player and seller identities. The synthetic name was edited through the social UI, then read by both applications; neither demo writes or recreates the profile. The connected checks below verify the underlying records as well as their rendered names.

## 4.5 Durability and extensibility

Application-named services let different clients interpret documents without changing the shared document schema. A conversation can be a group with message documents; a music library can define track services and listener roles; a shop can define catalog services. Domain-specific transactions, payment workflows, search indexes, schema evolution, and external integrations can extend this common substrate.

The durable separation is between stored content/access relationships and a particular frontend. Replacing a frontend can reuse those primitives when it understands their semantics. Moving providers is a larger task: identity continuity, document references, group grants, media, and remote relationships must survive export/import. The implemented query boundary is single-node; provider migration and federation are future work.

# 5 EVALUATION

The evaluation separates connected composition checks from preliminary metadata-resolution measurements. Both use synthetic data on a disposable single-node stack; neither is a capacity result for the deployed social service.

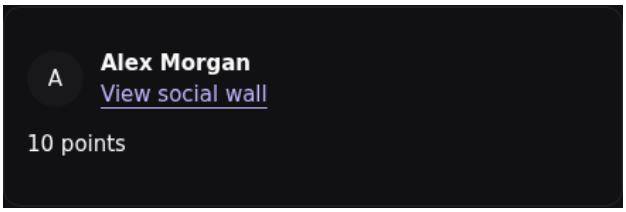
## 5.1 Connected interoperability

**Browser reuse.** A fresh account logged into web10-social through its authenticator popup and edited its profile name to Alex Morgan. The browser approved Snake's app request, earned and saved ten points, and displayed the joined profile. After app-contract revocation, a new query returned 403 and a leaderboard refresh cleared the result and displayed an access error. After sign-out, Marketplace requested its service permission through the popup, published a listing, and displayed the same profile. Reloading the listing's detail URL preserved that result. API assertions checked exact authors, row counts, profile bodies and listing identity, so the username fallback alone could not satisfy the test.

**Independent access controls.** A separate HTTP case used three accounts and two social-written profiles. It checked exact two-author score/profile and listing/profile joins. With no app permission for `profile`, both queries were denied; granting it enabled the joins, and revoking the app contract denied them again. A separately labeled private-profile fixture isolated the group gate: membership enabled an exact inner join; removal emptied it while the scores remained readable. The fixture did not replace the social-written profiles in the reuse checks. HTTP contracts were installed through the API; the browser sequence above exercised the actual consent UI.

All three cases—desktop at 1440 pixels, mobile at 375 pixels, and HTTP correctness—passed in the final fresh-stack run on 2 November 2026, with zero retries or skips. Six flow captures and two identity-card captures per viewport were retained and inspected. Iteration exposed a Marketplace race: the initial listing read could

**Snake: earned score + social identity**




**Marketplace: listing + social identity**

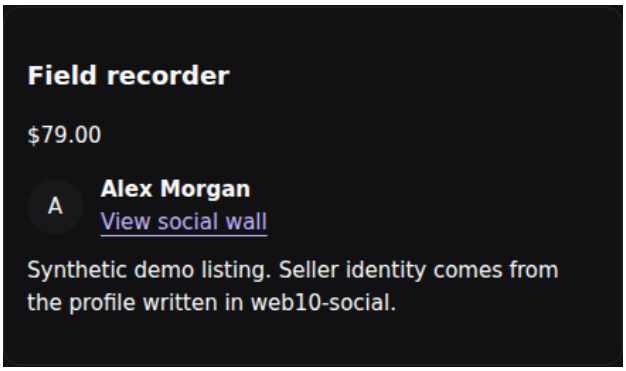



**Figure 3: One social-written profile, two application views. Snake joins an earned score to the player's profile; Marketplace joins a listing to the seller's same profile. These are direct browser element captures, with synthetic account and listing data. Full-page, consent, and denial captures are retained in the artifact.**

overwrite a successful publication's status. Keeping publication disabled until that read settled repaired it; a focused regression failed before the repair and passed afterward.

**Provenance and scope.** The run used revision `db897bccb` plus a retained patch/source overlay on a four-vCPU, 8-GB DigitalOcean sfo2 host, with ClickHouse 24.8.14.39, Playwright 1.63.0 and Chromium 153. The artifact contains source/config hashes, image identities, results and all 16 original captures. The API, authenticator and social frontend used development configurations; the marketing frontend was built. Schema initialization preceded API startup, avoiding the inherited fresh-stack ordering failure. Project storage and the droplet were removed after collection.

The hosted apps share one browser origin, although the HTTP case supplies a separate app Origin. They demonstrate reuse across applications, not separate browser-origin isolation or an independently recruited developer study. Clients know the profile format; automatic schema discovery is outside this result. Initial-letter avatars are not media-delivery evidence. These controls establish named grant/revocation behavior, not a stale-access or capability-expiry bound.

## 5.2 Preliminary metadata fan-out results

**Setup.** Table 3 reports one sequential trial on a DigitalOcean sfo2 `s-4vcpu-8gb` host (four vCPUs, 8 GB nominal RAM, Ubuntu 24.04, Linux 6.8, Docker 29.1.3), co-locating a single Uvicorn process and ClickHouse 24.3.18.7. The synthetic seed created 1,000 creators with one small post each and a reader who joined all their groups; those groups also granted public reads. Personal queries supplied $K = 10$, 100, or 1000 candidate groups on this same dataset and host. A separate discover query supplied one board group ($K = 1$), containing ten additional posts. Queries selected document IDs and bodies, ordered by creation time and ID, with a limit of 20. They did not execute engagement joins, media preparation or browser page assembly. HTTP requests supplied no Origin header, so this trial does not exercise the browser-origin app-contract gate.

**Variants.** The per-group resolver performs point metadata queries for each candidate group. The batched resolver fetches memberships, principal-class grants and role definitions across the candidate set in three database queries, then resolves access in memory. This reduces round trips, not the amount of permission metadata to process. We measured each resolver with real document execution (B) and a fixed 20-row synthetic scan result (C). C retains the policy/compilation path but is not an output-equivalent query execution. A third variant (A) precompiles the known-readable projection and times ClickHouse execution directly, outside the HTTP handler.

**Observed tradeoff.** Increasing $K$ from 10 to 1,000 increased B's median readable time by 100.44× for per-group resolution, versus 9.12× for batching. At $K = 1000$, batching reduced median readable time by 35.22× and median handler time by 21.04×. The per-group handler still completed requests, but its 7.64-second median exposes a practical bottleneck for this workload. C shows the same qualitative separation without the document scan: handler medians were 8.53 s per-group and 300 ms batched.

Three metadata round trips do not imply constant work. Batched B's handler median still grew 4.47× over the 100-fold increase in $K$, and its compilation median rose from 13.12 to 48.78 ms. Batching was not uniformly cheaper: at discover's $K = 1$, B's readable medians were 9.53 ms per-group versus 25.37 ms batched, with handler medians of 75.98 versus 87.51 ms. The results support reducing large-$K$ metadata fan-out, not a claim of constant latency.

**Baseline and scope.** A's median direct-scan times were 28.65, 29.99, and 54.17 ms at personal $K = 10$, 100, and 1000, respectively, and 29.92 ms for discover. Because A excludes authentication, compilation and serialization, subtracting A from B is a pipeline-versus-scan comparison, not a matched causal measurement of authorization overhead. All 20 cells captured 20 samples each: 400 measurements, comprising 320 successful B/C HTTP requests and 80 direct A executions. Twenty samples per cell provide only a preliminary p95; no independent trials, randomized order or explicit warm-up exclusion were used. This does not measure concurrent capacity, mixed allowed/denied access, discover scaling across node sizes,

**Table 3: Personal-query results from one sequential trial on the same 1,000-creator dataset, 20 samples per cell. B executes the document query; C substitutes a fixed 20-row result. Times are milliseconds. Readable denotes permission-resolution wall time; total denotes internal handler time, not end-to-end HTTP latency.**

| $K$ | Resolver | Variant | Readable median | Readable p95 | Total median | Total p95 |
|---|---|---|---|---|---|---|
| 10 | Per-group | B | 75.03 | 93.30 | 129.36 | 171.18 |
| 10 | Batched | B | 23.47 | 31.17 | 81.28 | 98.91 |
| 100 | Per-group | B | 764.39 | 843.21 | 831.35 | 915.18 |
| 100 | Batched | B | 41.78 | 51.65 | 99.42 | 139.47 |
| 1000 | Per-group | B | 7535.71 | 8504.61 | 7644.66 | 8679.24 |
| 1000 | Batched | B | 213.98 | 284.03 | 363.31 | 435.03 |
| 10 | Per-group | C | 76.36 | 88.84 | 104.96 | 134.30 |
| 10 | Batched | C | 27.07 | 33.60 | 59.91 | 85.53 |
| 100 | Per-group | C | 693.68 | 806.76 | 731.74 | 848.74 |
| 100 | Batched | C | 40.45 | 49.45 | 71.79 | 90.97 |
| 1000 | Per-group | C | 8388.39 | 9102.21 | 8529.75 | 9204.19 |
| 1000 | Batched | C | 222.57 | 281.20 | 299.59 | 350.27 |

or full-feed latency. HTTP success counts alone do not establish result equivalence or correctness across all policies.

**Provenance.** This trial used source revision `1a983520e` with no local source patches and seed 42. Seeding completed on the first attempt in 818.3 s; artifacts were collected before droplet deletion. The experiment record and retained machine-readable report supply cell accounting and phase summaries, not raw per-request observations. An earlier 100-creator trial at $K = 10/100$ showed the same qualitative tradeoff, but used a different dataset, host and source snapshot (`cf7943c88` plus a settings fix). Its samples are not pooled with this table or treated as independent repetitions of this configuration. That earlier trial's initial seed failed with HTTP 500 responses and lost server logs; its cause remains unresolved. The later first-attempt success does not establish general unattended startup reliability.

An industry evaluation needs dated production observations separated from synthetic runs. Production observations should identify deployment duration, registered and active users, live and versioned document counts, services, groups, membership distributions, object volume, and operation rates. Logical user namespaces are counted separately from physical storage. Availability, recovery, and operating costs use explicit observation windows, failure definitions, and accounting boundaries.

## 5.3 Remaining workload measurements

Experiments should pin the source revision, dependency and engine versions, schema, data generator and seed, hardware, storage, network placement, worker counts, connection limits, and database settings. A localhost harness excludes wide-area latency but still includes scheduling, queueing, container networking, and service waits; it is not a browser experience measurement. Browser traces must separately capture group discovery, main and follow-up queries, media fetches, and time to a defined render milestone.

Vary document count, versions per document, groups per reader, services per query, group overlap, response size, ranking complexity, and concurrent writes. Include member, public-class, authenticated-class, denied, and anonymous reads, as well as posting, direct-message, and group flows. Multi-group attachments need explicit duplicate/-counting semantics. State warm-up, cache conditions, run length, offered-load model, concurrency, repeated runs, and uncertainty. Report successful throughput, errors and timeouts alongside end-to-end p50/p95/p99 latency; a latency distribution of successful requests alone can hide overload. Separate API and ClickHouse CPU/memory, storage growth, merge activity, internal query counts, and resource cost.

The query telemetry times authentication, app contracts, parsing/validation, candidate discovery, readable-group resolution, group metadata, compilation, execution, serialization, preparation, and total handler duration. Phase wall times include waits and do not directly measure Python CPU. The ratio of the median readable-group phase to median execution time is a descriptive ratio, not total authorization overhead: policy also changes compilation and the SQL executed, and ratios of medians are not distributions of per-request overhead. Instrumentation coverage, including work outside named phases, must be stated.

## 5.4 Baselines and broader correctness

A conventional shared-table backend with dynamic PostgreSQL RLS provides a baseline [13]. Match returned content, membership/class grants, visibility exclusions, ranking, pagination, preparation, consistency requirements, and hardware/resource budgets. Document indexes, caching, batching, and implementation differences. Compare full flows as well as database queries. Both systems use shared tables and logical user namespaces.

A separate authorization-disabled ablation on isolated synthetic data can measure the cost of checks removed from an otherwise matched request. Account for both metadata orchestration and changes to generated query plans; retain equivalent access semantics for the product baseline. Comparisons with Pod or federated architectures also account for placement, autonomy, caching, and network topology.

Beyond the connected controls above, broader correctness evaluation needs a pinned test matrix and actual results, distinguishing unit tests, mocked endpoints, and live-store and browser tests. Cover principal classes, membership admission, service permissions,

tombstones, multi-group rows, aggregations, nested SQL, denied raw tables/functions, and capability issuance. Establishing revocation latency bounds requires racing grant changes with reads and measuring stale access through metadata visibility, in-flight requests, and issued URLs/manifests.

### 5.5 Scope and open boundaries

This case study covers a single-node architecture and implemented application patterns. Production-scale adoption, exhaustive competitor feature parity, catalog and recommendation quality, and cross-node migration are outside the evaluation. Performance results will be reported for the measured workloads and configurations.

Security evidence consists of regression tests and the named connected controls. Whole-system conformance and the ongoing credential, consent/delegation, and media reviews remain open. In particular, a separate read-URL handler forwards caller-selected keys to signing without an intervening object check. The recorded local probe demonstrates that forwarding; actual private-object retrieval remains unverified. Parser/engine semantic differences and result-projection provenance also require targeted testing. These boundaries are part of the follow-up correctness work alongside performance optimization.

## 6 RELATED WORK

**Decentralized social data.** ActivityPub [11] defines client/server and federated server/server activity delivery. ATProto's repositories, relays, and AppViews separate storage from application views and support user agency and provider switching [10]. web10 focuses on query composition within a node: app-defined service queries read a shared store through relations filtered for the reader at request time. Federation and provider migration address complementary system boundaries.

Solid separates applications from personal data stores [15], with social application work [14] and a maintained Community Solid Server [7]. WAC supports resource permissions and group agents through `acl:agentGroup` [5]; ACP includes agent, client, and issuer matching [3]. web10 packages group membership, join policies, and per-service role maps with a shared relational query path. Pods are logical stores that need not each occupy a separate server; cross-store query cost depends on deployment, caching, indexing, and query strategy. The comparison here concerns data placement and query interfaces; a performance comparison would require a matched workload and deployment.

**Cloud IAM.** AWS IAM (documentation) [1] and the RBAC/ABAC literature [6, 8, 16] provide the policy concepts web10 adapts at the user boundary: principals, roles, service-scoped operations, revocable grants. The move in this paper is directional—a familiar policy vocabulary exposed to users about their own content and groups, orchestrated by the API and query layer. At industrial scale, relationship-based authorization (Zanzibar [12]) shows a uniform ACL data model and consistency as a first-class problem. Its consistency guarantees motivate explicit evaluation of web10's revocation visibility. TAO [4] provides a social-graph storage precedent, whereas web10 composes application queries over service-namespaced documents in a columnar store.

**Multi-tenant isolation.** The database literature on tenant isolation—shared tables with an organization identifier (Force.com [18]), schema-mapping techniques [2], and the shared-versus-separate spectrum [9]—is the closest systems ancestor. web10's key-space per user makes the *end user* the logical tenant. Authorship uses `author_key`; shared reads use authorized group relations rather than a physical database boundary. PostgreSQL row-security policies [13] are an alternative location for dynamic access enforcement. Matched policy and workload execution (§5) can distinguish the costs of these enforcement placements. ClickHouse [17] supplies the columnar execution engine; web10 supplies the access orchestration above it, including metadata resolution, SQL compilation, and result preparation.

## 7 CONCLUSION

web10 makes content and access relationships a shared substrate for application queries. Logical user namespaces, app contracts, and generic groups connect user-managed access to a columnar store; the query layer supplies the reader's service relations before joins and aggregation. The social application shows how this separation supports ranked feeds and scoped engagement reads while keeping query definitions in the application.

The connected game and marketplace extend that separation beyond the social interface: each joins its own records to social-written profiles without a new node endpoint or a change to the social application. Browser consent and cross-author app/group controls make this a demonstrated composition path, rather than a hypothetical extension to other application domains.

The preliminary trial identifies per-group metadata round trips as a concrete bottleneck: at 1,000 candidate groups, batching reduced median handler time from 7.64 s to 363 ms, while costing more at one group. This motivates batching as an implementation choice, not a claim of unbounded scalability. Repeated trials, representative application workloads, concurrent load and revocation measurements remain necessary to establish a practical operating point. The architectural contribution is this integration: applications compose social views over reader-specific service relations in a shared columnar store.

## REFERENCES

[1] Amazon Web Services. 2025. AWS Identity and Access Management (IAM) User Guide. Amazon Web Services documentation. https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction.html

[2] Stefan Aulbach, Torsten Grust, Dean Jacobs, Alfons Kemper, and Jan Rittinger. 2008. Multi-Tenant Databases for Software as a Service: Schema-Mapping Techniques. In *Proceedings of the 2008 ACM SIGMOD International Conference on Management of Data (SIGMOD '08)*. ACM, 1195–1206.

[3] Matthieu Bosquet. 2022. Access Control Policy (ACP). W3C Solid Community Group, Editor's Draft. https://solid.github.io/authorization-panel/acp-specification/

[4] Nathan Bronson, Zach Amsden, George Cabrera, Prasad Chakka, Peter Dimov, Hui Ding, Jack Ferris, Anthony Giardullo, Sachin Kulkarni, Harry C. Li, Mark Marchukov, Dmitri Petrov, Lovro Puzar, Yee Jiun Song, and Venkateshwaran Venkataramani. 2013. TAO: Facebook's Distributed Data Store for the Social Graph. In *Proceedings of the 2013 USENIX Annual Technical Conference (USENIX ATC '13)*. USENIX Association, 49–60.

[5] Sarven Capadisli. 2022. Web Access Control. W3C Solid Community Group, Version 1.0.0-cr-1. https://solidproject.org/TR/wac

[6] David F. Ferraiolo and David R. Kuhn. 1992. Role-Based Access Controls. In *Proceedings of the 15th National Computer Security Conference*. 554–563.

[7] Joachim Van Herwegen and Ruben Verborgh. 2024. The Community Solid Server: Supporting Research and Development in an Evolving Ecosystem. *Semantic Web* 15, 6 (2024), 2597–2611. https://doi.org/10.3233/SW-243726

[8] Vincent C. Hu, David F. Ferraiolo, David R. Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone. 2014. *Guide to Attribute Based Access Control (ABAC) Definition and Considerations.* Technical Report SP 800-162. National Institute of Standards and Technology. Includes updates as of August 2019.

[9] Dean Jacobs and Stefan Aulbach. 2007. Ruminations on Multi-Tenant Databases. In *Proceedings of BTW 2007*. 514–521.

[10] Martin Kleppmann, Paul Frazee, Jake Gold, Jay Graber, Daniel Holmgren, Devin Ivy, Jeromy Johnson, Bryan Newbold, and Jaz Volpert. 2024. Bluesky and the AT Protocol: Usable Decentralized Social Media. In *Proceedings of the ACM CoNEXT-2024 Workshop on the Decentralization of the Internet (DIN '24)*. ACM, 9. https://doi.org/10.1145/3694809.3700740 Extended version: arXiv:2402.03239.

[11] Christine Lemmer-Webber, Jessica Tallon, Erin Shepherd, Amy Guy, and Evan Prodromou. 2018. ActivityPub. W3C Recommendation. https://www.w3.org/TR/activitypub/ Editors: Christine Lemmer-Webber and Jessica Tallon.

[12] Ruoming Pang, Ramon Caceres, Mike Burrows, Zhifeng Chen, Pratik Dave, Nathan Germer, Alexander Golynski, Kevin Graney, Nina Kang, Lea Kissner, Jeffrey L. Korn, Abhishek Parmar, Christina D. Richards, and Mengzhi Wang. 2019. Zanzibar: Google's Consistent, Global Authorization System. In *Proceedings of the 2019 USENIX Annual Technical Conference (USENIX ATC '19)*. USENIX Association. https://www.usenix.org/system/files/atc19-pang.pdf

[13] PostgreSQL Global Development Group. n.d. PostgreSQL Documentation: Row Security Policies. PostgreSQL documentation. https://www.postgresql.org/docs/current/ddl-rowsecurity.html Accessed October 2026.

[14] Andrei Sambra, Amy Guy, Sarven Capadisli, and Nicola Greco. 2016. Building Decentralized Applications for the Social Web. In *Proceedings of the 25th International Conference Companion on World Wide Web (WWW '16 Companion)*. ACM, 1033–1034.

[15] Andrei Vlad Sambra, Essam Mansour, Sandro Hawke, Maged Zereba, Nicola Greco, Abdurrahman Ghanem, Dmitri Zagidulin, Ashraf Aboulnaga, and Tim Berners-Lee. 2016. *Solid: A Platform for Decentralized Social Applications Based on Linked Data.* Technical Report. MIT CSAIL and Qatar Computing Research Institute. http://emansour.com/research/lusail/solid_protocols.pdf

[16] Ravi S. Sandhu, Edward J. Coyne, Hal L. Feinstein, and Charles E. Youman. 1996. Role-Based Access Control Models. *IEEE Computer* 29, 2 (1996), 38–47.

[17] Robert Schulze, Tom Schreiber, Ilya Yatsishin, Ryadh Dahimene, and Alexey Milovidov. 2024. ClickHouse: Lightning Fast Analytics for Everyone. *Proceedings of the VLDB Endowment* 17, 12 (2024), 3731–3744. https://doi.org/10.14778/3685800.3685802

[18] Craig D. Weissman and Steve Bobrowski. 2009. The Design of the Force.com Multitenant Internet Application Development Platform. In *Proceedings of the 2009 ACM SIGMOD International Conference on Management of Data (SIGMOD '09)*. ACM, 889–896. https://doi.org/10.1145/1559845.1559942